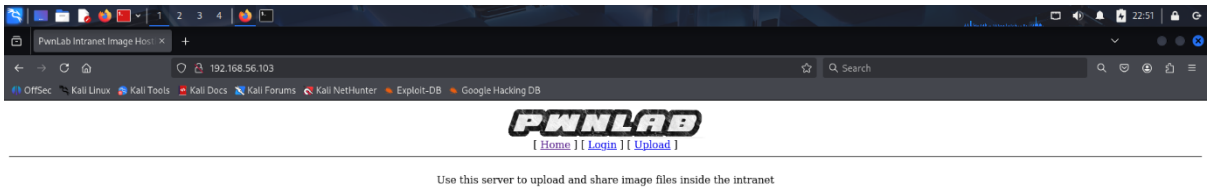
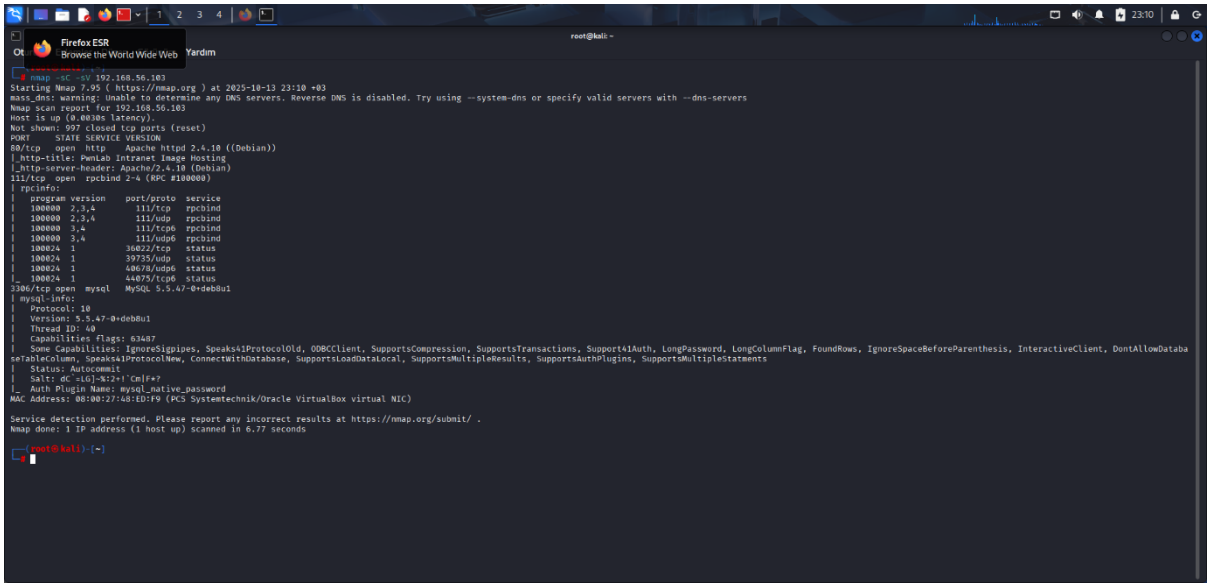
PWNLAB İNİT:

Klasik bir şekilde bu ctf ye de başlıyorum ve direk hedefin ip numarasını öğrenmek için tarama başlatıyorum.

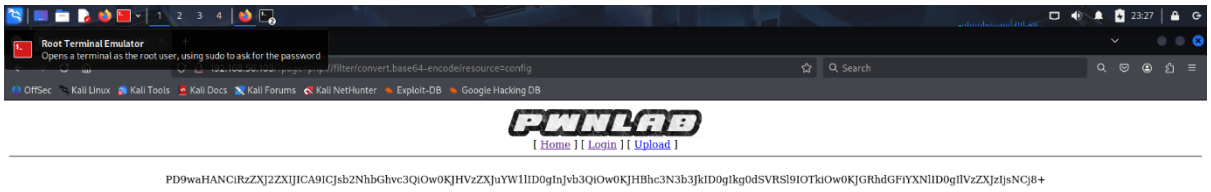
Burda ip adresini öğrendikten sonra hemen siteye giriyorum.



Bu arada bir nmap taraması ile hangi sql in kullanıldığını ve açık portu öğreniyoruz.



Dirsearch taraması ile login , upload, config phplerini görüyorum ve confige gidiyorum



Burayı decode edince bana direk username ve passwd veriyor. Sonrasında sitede bir şey bulamıyorum ve elde ettiğim bilgier ile veritabanına giriş yapmaya çalışacağım ordan diğer kulllanıcı bilgilerini çekebileceğimi zamanında öğrendim biliyorum.

```
┌──(root㉿kali)-[~]
└─# mysql -u root -p -h 192.168.56.105
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it

┌──(root㉿kali)-[~]
└─#

┌──(root㉿kali)-[~]
└─# mysql -u root -p -h 192.168.56.105 --ssl-mode=DISABLED
mysql: unknown variable 'ssl-mode=DISABLED'

┌──(root㉿kali)-[~]
└─# telnet 192.168.56.105 3306
Trying 192.168.56.105 ...
Connected to 192.168.56.105.
Escape character is '^]'.
S
5.5.47-0+deb8u1,Iu28`]3*\!0jJnob{dcEmysql_native_passwordConnection closed by foreign host.

┌──(root㉿kali)-[~]
└─# mysql -u root -p -h 192.168.56.105 --ssl=0
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 45
Server version: 5.5.47-0+deb8u1 (Debian)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> use Users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [Users]> show tables;
+-------------+
| Tables_in_Users |
+-------------+
| users       |
+-------------+
1 row in set (0,003 sec)

MySQL [Users]>
```

Burada user tablolarını doğru sql komuları kullanarak çıkarıyorum ve kullanıcı tablolarına ulaşıyorum şimdilik sadece birini decode ediyorum onun için kenti seçiyorum.

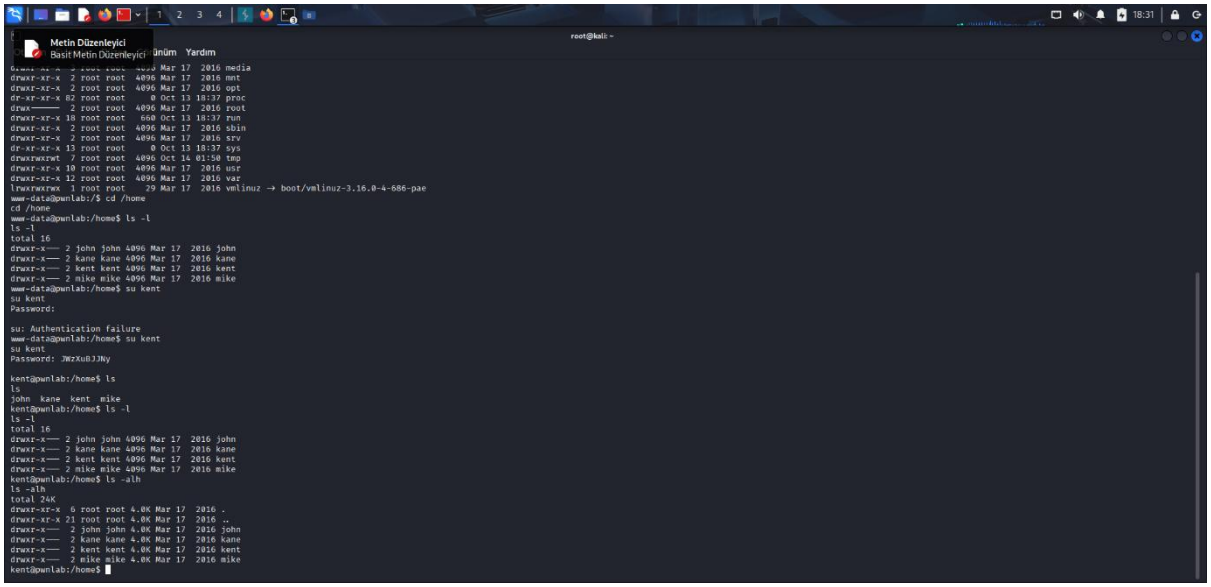
```
┌──(root㉿kali)-[~]
└─# echo "sld6WHVCSkpDeq==" | base64 -d
JWzXuBJJNy

┌──(root㉿kali)-[~]
└─#
```

Ve uygulamaya kent olarak giriş yapıyorum.

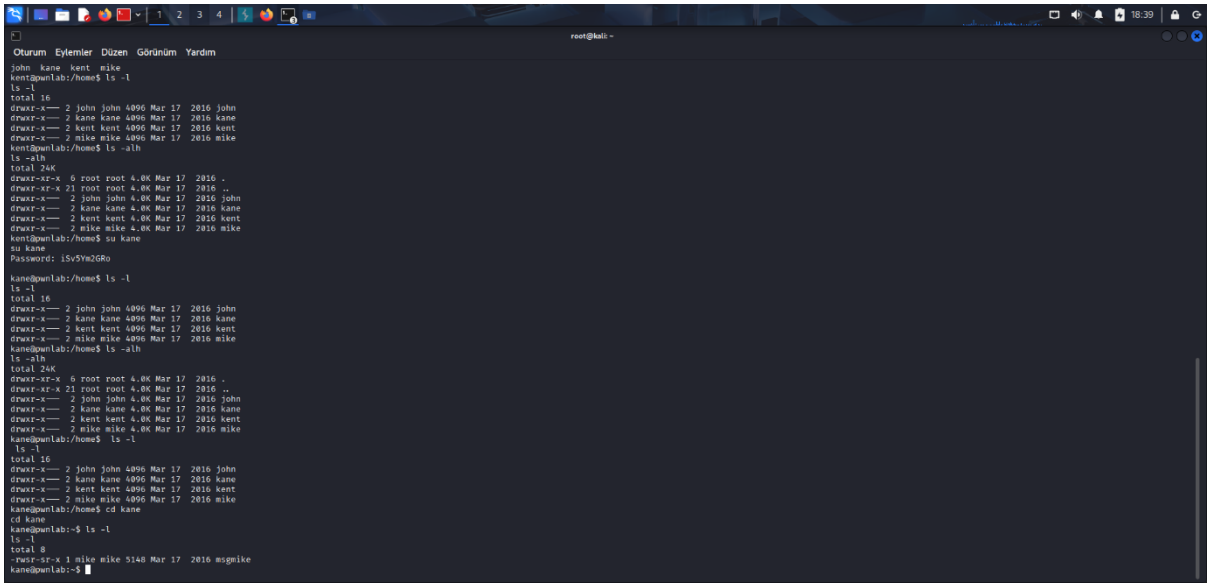
Asıl olay şimdi başlıyor. Site benden bir php dosyası girmemi istiyor ve bunu ilk başta beceremedim araştırdıktan sonra bir php.reverse dosyası indirdim. Kaynak kodda dosyanın sadece gif,jpeg şeklinde olacağını görüyorum. Bunun için dosyamın başına GIF98 koyuyorum ve port yerine 4444 (buradan dinleme yapacağım) ip kısmına da kendi ip numaramı yazıyorum. Ve dinleme açıp php dosyamı yüklüyorum ama hiç bir şey olmuyor. Sebebi kaynak kodda lang kullanılmış olması ama bir araştırma

sonrası lang ve cookie arasında bir zafiyet olduğunu görüyorum. Sonrasında aynı şekilde isteği burp e atıyorum ve orada cookie kısmına lang yazıp dosyanın uzantısını ekliyorum ve dinleme kısmını artık başarıyorum.

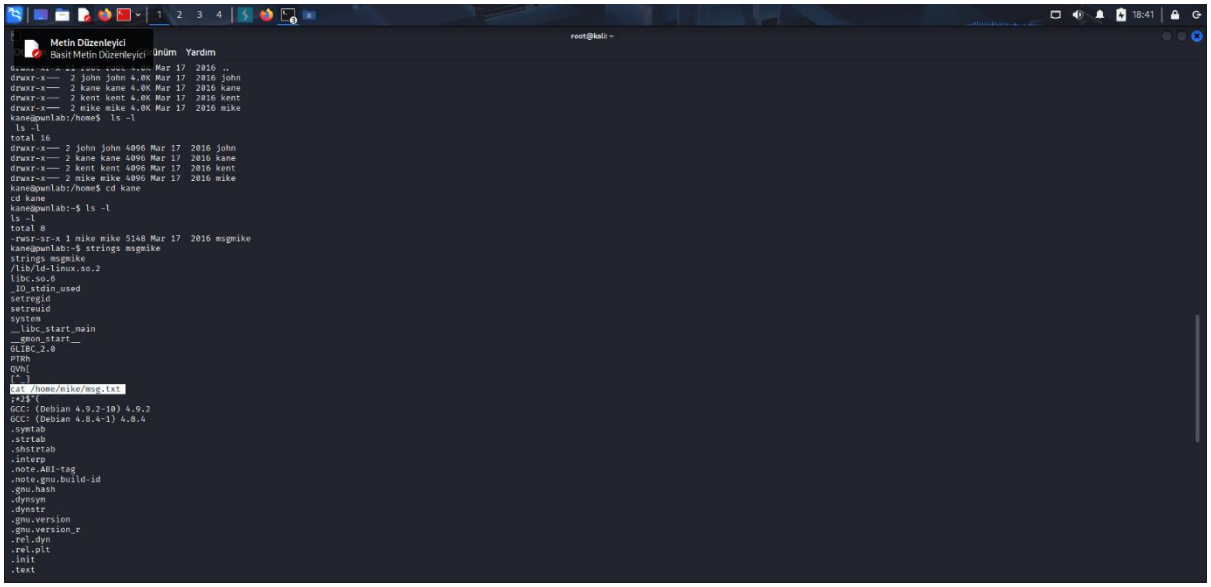
Burada whoami sorgusu ile data olduğumu öğreniyorum ve su kent yazıyorum sonrasında sisteme kane olarak giriş yapıyorum artık kent oldum.



Ls-l ile inceleme yapıyorum ama dikkatimi bir şey çekmior ve kane e geçiş yapıyorum. Kane de ls-l yapınca msgmike diye bir şey görüyorum.

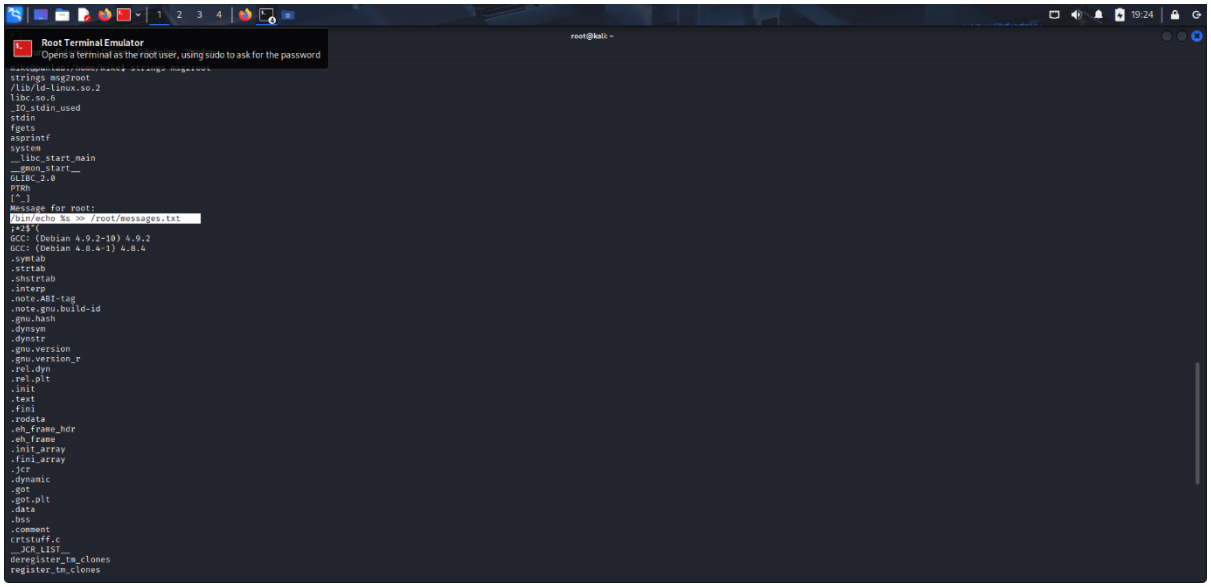


Şimdi bu msgmike dosyasını daha da genişletip incelemek için strings msgmike yapıyorum ve burada /home/mike/msg.txt dosyasının okunmaya çalışıldığını görüyorum.

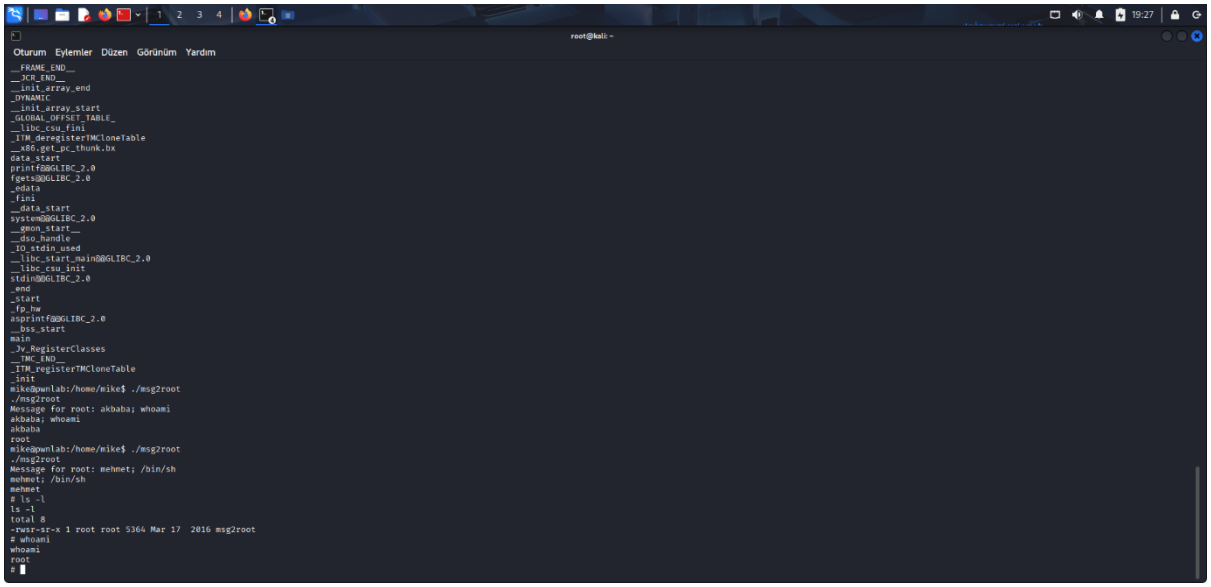


Burada şunu öğreniyorum cat komutu path belirtilmeden kullanılmadan çalıştırılmış yani cat adında zararlı bir dosya oluşturupbunu yetki atlamak için kullanacağım. Şimdi tmp dizininde kötü niyetl bir cat dosyası oluşturp onu çalıştırmaya uğraşacağım içine /bin/sh yazıyorum. BU şekilde mike ı çalıştırınca mike olarak sisteme girdim sonlara yaklaştığımı artık anlamış oldum.

Artık mike olarak sistemdeyim ve hemen ls-l yapyorum. ÜStteki görselde görüldüğü gibi burada da ms2root diye bir dosya var bu yüzden hemen strings ms2root a bakıyorum.



Burada kodun /bin/echo şeklinde çalıştığını görüyorum ve araştırdıktan sonra öğreniyorum ki biz içeriye /bin/sh şeklinde zararlı dosyayı yazdıktan sonra root olabileceğiz. Şimdi .msg2root yazdıktan sonra bizden bir mesaj istiyor ve bu mesaja /bin/sh yazdıktan sonra root oluyorum.



Artık son raddeye geliyorum ve txt dosyasını çalıştırmaya çalışıyorum bir kaç kez başarısız olduktan sonra en son txt dosyasını çalıştırıp flag i elde ediyorum.

YAPTIKLARIM VE ÖZET

Öncelikle bu CTF geçenkine göre daha zor çünkü geçen CTF de bayraklar benim doğru yolda olduğumu gösteriyordu ve anlıyordum. Ama burada daha fazla komut çalıştırdım MYSQL e giriş yapmayı öğrendim shell php dosyasını gif e döndürmeyi öğrendim bana bayağı bir yararı oldu. Bazı yerlerde gerçekten çok oyalandım, zorlandım, nereden gideceğimi bilemedim Ama galiba artık bu CTF ile brilikte nerelerden ilerleyeceğimi

daha çok biliyorum biraz daha kendime bir şeyler kattığımı geliştiğimi düşünüyorum. Nerelere dikkat etmem gerektiğine dair biraz daha bir şeyler öğrendim ve yine de zevk alarak eğlenerek yaptığım bir ctf oldu.